UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

| | | |
|---|---|---|
| COURSE | : | COMPUTER SECURITY |
| COURSE CODE | : | CSC662 |
| EXAMINATION | : | OCTOBER 2026 (MOCK) |
| TIME | : | 3 HOURS |

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 0 slot(s). Supported theory: 24 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

*This marking scheme consists of 15 printed pages*

© Hak Cipta Universiti Teknologi MARA 

# CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

*Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.*

*Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.*

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 0 computed, 24 supported by lecture slides, 0 placeholder.

*Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.*

## PART A - QUESTION 1

### A1a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain the difference between morals, ethics and laws as three distinct forms of guidance for conduct.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Morals are described as traditions of belief concerning right and wrong conduct, forming the basis of social behaviour. | "Morals are traditions of belief about right and wrong conduct" | 071 - Ethics and Computer Security, slide 5 | 071 - Ethics and Computer Security::s05::1 | 0.55 | supported (ste gate) |
| 2 | Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens. | "Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens" | 071 - Ethics and Computer Security, slide 5 | 071 - Ethics and Computer Security::s05::1 | 1.00 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 071 - Ethics and Computer Security, slide 5*

### A1b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain six ways in which a professional code of ethics and conduct, such as the ACM code, guides the behaviour of a computing professional.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | A code of ethics is a documented set of acceptable behaviours for a professional or social group. | "Documented set of acceptable behaviors for professional or social groups." | 071 - Ethics and Computer Security, slide 6 | 071 - Ethics and Computer Security::s06::1 | 0.67 | supported (ste gate) |
| 2 | The code is defined by the professional group itself. | "Defined by the group." | 071 - Ethics and Computer Security, slide 6 | 071 - Ethics and Computer Security::s06::1 | 0.40 LOW | supported |
| 3 | It identifies which specific actions are appropriate or inappropriate. | "Identifies specific actions as appropriate or inappropriate." | 071 - Ethics and Computer Security, slide 6 | 071 - Ethics and Computer Security::s06::1 | 1.00 | supported (ste gate) |
| 4 | It requires the professional to contribute to society and human well-being, | "Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing." | 071 - Ethics and Computer Security, slide 11 | 071 - Ethics and Computer Security::s11::1 | 0.70 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA 

| | | | | | | |
|---|---|---|---|---|---|---|
| | recognising all people as stakeholders. | | | | | |
| 5 | It obliges the professional to respect privacy and honour confidentiality. | "Respect privacy." | 071 - Ethics and Computer Security, slide 11 | 071 - Ethics and Computer Security::s11::1 | 0.33 LOW | partly supporte |
| 6 | It directs the professional to maintain high standards of professional competence, conduct and ethical practice. | "Maintain high standards of professional competence, conduct, and ethical practice." | 071 - Ethics and Computer Security, slide 12 | 071 - Ethics and Computer Security::s12::1 | 0.89 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12; 071 - Ethics and Computer Security, slide 6*

## PART A - QUESTION 2

### A2a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State TWO (2) formal security models that are classified as information flow models, and state the specific concern that the Chinese Wall model is designed to address.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The Chinese Wall model is listed as an information flow model concerned with identifying conflicts of interest. | "Chinese Wall model: identification of conflicts of interest" | 024 - Formal Security Model, slide 5 | 024 - Formal Security Model::s05::1 | 0.62 | supported (ste gate) |
| 2 | The Chinese Wall policy is designed to address the specific concern of conflicts of interest by a consultant or contractor. | "Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor." | 024 - Formal Security Model, slide 27 | 024 - Formal Security Model::s27::1 | 1.00 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 024 - Formal Security Model, slide 27; 024 - Formal Security Model, slide 5*

### A2b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain the three main access control structures used to implement access policies, namely the access control matrix, access control lists and capabilities, and for each structure state one advantage or disadvantage associated with its use.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The access control matrix is described as a basic control structure for implementing access policies. | "ACM is a basic control structure." | 023 - Access Control and Authorization, slide 8 | 023 - Access Control and Authorization::s08::1 | 0.43 LOW | supported |
| 2 | A strength of the access control matrix is that it is clear to define and easy to verify. | "clarity of definition easy to verify" | 023 - Access Control and Authorization, slide 8 | 023 - Access Control and Authorization::s08::1 | 0.25 LOW | supported |
| 3 | A weakness of the access control matrix is that it scales poorly and handles changes poorly. | "poor scalability poor handling of changes" | 023 - Access Control and Authorization, slide 8 | 023 - Access Control and Authorization::s08::1 | 0.38 LOW | supported |
| 4 | An access control list is | "ACL is an object-centered | 023 - Access | 023 - Access | 0.57 | supported (ste |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | an object-centred description of the access rights held on that object. | description of access rights:" | Control and Authorization, slide 10 | Control and Authorization::s10::1 | | gate) |
| 5 | Access control lists make it easy to see and manage the access rights on an object, including through abstractions. | "easy access to object access rights relative easiness of management using abstractions" | 023 - Access Control and Authorization, slide 10 | 023 - Access Control and Authorization::s10::1 | 0.55 | supported (ste gate) |
| 6 | Access control lists suffer from a poor overview of a subject's rights and from difficulty in revoking and sharing rights. | "poor overview of access rights per subject difficulty of revocation difficulty of sharing" | 023 - Access Control and Authorization, slide 10 | 023 - Access Control and Authorization::s10::1 | 0.60 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 8*

## PART A - QUESTION 3

### A3a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State TWO (2) points about software insecurity and buffer overflows as presented in the Software Security lecture.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Software insecurity arises because an attacker can modify system resources that are critical for program execution, such as the instruction pointer or function call addresses. | "Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc." | 051 - Software Security, slide 30 | 051 - Software Security::s30::1 | 0.72 | supported (ste gate) |
| 2 | Buffer overflows are one of the most widely used exploitation techniques. | "Buffer overflows are a most widely used exploitation technique." | 051 - Software Security, slide 30 | 051 - Software Security::s30::1 | 0.83 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 051 - Software Security, slide 30*

### A3b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain six (6) aspects of Windows security mechanisms as presented in the Windows Security lecture, covering the role of subjects and tokens, the purpose of Active Directory, the nature of Windows access control, and the risks arising from the complexity of these mechanisms.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Identify what Windows treats as subjects, namely processes and threads. | "Windows subjects are processes and threads." | 041 - Windows Security, slide 11 | 041 - Windows Security::s11::1 | 0.80 | supported (ste gate) |
| 2 | State where the security credentials of a subject are kept, i.e. in a token. | "Security credentials for a subject are stored in a token." | 041 - Windows Security, slide 11 | 041 - Windows Security::s11::1 | 0.67 | supported (ste gate) |
| 3 | Describe Active Directory as an LDAP- | "Active directory introduced in Windows 2000 is an LDAP-like directory service for organization | 041 - Windows Security, slide 6 | 041 - Windows Security::s06::1 | 0.91 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | like directory service introduced in Windows 2000 for organising system resources. | of system resources:" | | | | |
| 4 | Note that Windows systems provide complex mechanisms for user account and object management and for access control. | "Windows systems contain complex security mechanisms for user account and object management as well as access control." | 041 - Windows Security, slide 21 | 041 - Windows Security::s21::1 | 0.83 | supported (ste gate) |
| 5 | Explain that DACS allow fine-grained access control over heterogeneous entities both in Windows itself and in applications. | "DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications." | 041 - Windows Security, slide 21 | 041 - Windows Security::s21::1 | 0.69 | supported (ste gate) |
| 6 | Warn that the complexity of Windows security mechanisms can itself cause severe security incidents through misconfiguration or implementation bugs. | "The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents." | 041 - Windows Security, slide 21 | 041 - Windows Security::s21::1 | 0.57 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 21; 041 - Windows Security, slide 6*

# PART A - QUESTION 4

## A4a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*A biometric system performs its work in two broad stages. List the TWO (2) stages of the biometric authentication process.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Identification stage, in which the master characteristics are acquired, created and stored | "Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics" | 072 - Biometrics and Authentication, slide 5 | 072 - Biometrics and Authentication::s05::1 | 0.50 | supported (ste gate) |
| 2 | Authentication stage, in which acquisition is repeated and the result is compared and a decision made | "Authentication Stage Acquisition(s) Comparison Decision" | 072 - Biometrics and Authentication, slide 5 | 072 - Biometrics and Authentication::s05::1 | 0.57 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 072 - Biometrics and Authentication, slide 5*

## A4b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Refer to your answer in (a). Discuss biometric mechanisms and technologies as an alternative to passwords, covering the definition of a biometric, the two categories of biometric applications, and the specific technologies with their limitations.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | A biometric is defined as a physiological or behavioural characteristic of a human being that can distinguish one person | "A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of | 072 - Biometrics and Authentication, slide 2 | 072 - Biometrics and Authentication::s02::1 | 0.92 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | from another and can theoretically be used for identification or verification of identity. | identity." | | | | |
| 2 | Biometric applications are categorized into two sectors: psychological and behavioural. | "Biometric applications available today are categorized into 2 sectors" | 072 - Biometrics and Authentication, slide 4 | 072 - Biometrics and Authentication::s04::1 | 0.71 | supported (ste gate) |
| 3 | The psychological category includes iris, fingerprints, hand, retinal and face recognition. | "Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition" | 072 - Biometrics and Authentication, slide 4 | 072 - Biometrics and Authentication::s04::1 | 0.78 | supported (ste gate) |
| 4 | The behavioural category includes voice, typing pattern and signature. | "Behavioural: Voice, Typing pattern, Signature" | 072 - Biometrics and Authentication, slide 4 | 072 - Biometrics and Authentication::s04::1 | 0.67 | supported (ste gate) |
| 5 | Retinal scanning is very efficient and cannot be spoofed, but it has disadvantages such as the user having to look directly, a high FTE ratio, acceptability concerns, light exposure and hygiene. | "Very efficient - cant be spoofed!" | 072 - Biometrics and Authentication, slide 9 | 072 - Biometrics and Authentication::s09::1 | 0.14 LOW | partly supporte |
| 6 | Fingerprint biometrics suffer from disadvantages including racial issues, dirt, grime and wounds, placement of finger, too big a database to process, and spoofing so liveness is important. | "Can be spoofed - liveness important!" | 072 - Biometrics and Authentication, slide 7 | 072 - Biometrics and Authentication::s07::1 | 0.16 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7; 072 - Biometrics and Authentication, slide 9*

## PART A - QUESTION 5

### A5a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State TWO (2) password security controls that can be applied to protect password files and accounts.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Applying access control to password files | "Access control applied to password files" | 022 - Identification and Authentication, slide 12 | 022 - Identification and Authentication::s12::1 | 0.80 | supported (ste gate) |
| 2 | Deactivating accounts after multiple failed login attempts | "De-activation of accounts after multiple failed logins" | 022 - Identification and Authentication, slide 12 | 022 - Identification and Authentication::s12::1 | 0.71 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 022 - Identification and Authentication, slide 12*

### A5b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State SIX (6) facts about Kerberos and single sign-on (SSO) as authentication mechanisms, covering the*

*motivation for SSO, the design criteria of Kerberos, and the strengths and weaknesses of Kerberos.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | One motivation for single sign-on is to reduce the number of passwords users must memorize. | "Reduce the need to memorize passwords" | 022 - Identification and Authentication, slide 16 | 022 - Identification and Authentication::s16::1 | 0.33 LOW | supported |
| 2 | Single sign-on can be implemented through client-server architectures such as Kerberos or Active Directory. | "Client-server architectures (Kerberos, Active Directory)" | 022 - Identification and Authentication, slide 16 | 022 - Identification and Authentication::s16::1 | 0.50 | supported (ste gate) |
| 3 | Kerberos is designed to resist eavesdropping by never transmitting passwords in clear text. | "Security against eavesdropping: no password transmission in clear text." | 022 - Identification and Authentication, slide 18 | 022 - Identification and Authentication::s18::1 | 0.44 LOW | supported |
| 4 | Kerberos is designed for transparency, so the user is unaware of any authentication beyond the initial login. | "Transparency: user is not aware of any authentication beyond an initial login." | 022 - Identification and Authentication, slide 18 | 022 - Identification and Authentication::s18::1 | 0.70 | supported (ste gate) |
| 5 | Kerberos provides secure authentication even over an insecure network. | "Provides secure authentication in an insecure network." | 022 - Identification and Authentication, slide 23 | 022 - Identification and Authentication::s23::1 | 0.62 | supported (ste gate) |
| 6 | A weakness of Kerberos is that it constitutes a single point of failure. | "Single point of failure." | 022 - Identification and Authentication, slide 23 | 022 - Identification and Authentication::s23::1 | 0.50 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 23*

# PART A - QUESTION 6

## A6a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain two characteristics of Trojan horse malware as described in the lecture, focusing on how it behaves and what it does to the host system.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Trojans disguise themselves as useful or benign software so that users install them unsuspectingly. | "They usually masquerade as helpful or harmless programs" | 051 - Software Security, slide 12 | 051 - Software Security::s12::1 | 0.00 LOW | supported |
| 2 | Once running, a Trojan steals private data, deletes files, records keystrokes, or creates a way for further malware to be installed. | "begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed" | 051 - Software Security, slide 12 | 051 - Software Security::s12::1 | 0.60 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 051 - Software Security, slide 12*

## A6b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Discuss six malware attack techniques and propagation methods described in the lecture, explaining for each how the technique operates and what impact it has on the infected system or its users.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Rootkits conceal malicious processes and software on the infected machine so that the attacker retains privileged remote access. | "Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access." | 051 - Software Security, slide 13 | 051 - Software Security::s13::1 | 0.67 | supported (ste gate) |
| 2 | Rootkits are typically installed after a vulnerability has been discovered, allowing the attacker to keep control of the compromised computer. | "They are usually installed after a vulnerability has been found and detected so that the infected computer continues to be under the control of the malware author." | 051 - Software Security, slide 13 | 051 - Software Security::s13::1 | 0.46 LOW | supported |
| 3 | Spyware gathers sensitive user data such as logins, passwords, visited sites and keystrokes, and can redirect the browser to unwanted sites. | "They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites." | 051 - Software Security, slide 13 | 051 - Software Security::s13::1 | 0.60 | supported (ste gate) |
| 4 | An executable-file virus can propagate by appending its virus body to a host program. | "Append a virus body to a program" | 051 - Software Security, slide 10 | 051 - Software Security::s10::1 | 0.44 LOW | supported |
| 5 | An executable-file virus can hijack execution by overwriting the program header so that the entry point switches to the virus. | "Over write a program header to switch the entry point to a virus" | 051 - Software Security, slide 10 | 051 - Software Security::s10::1 | 0.55 | supported (ste gate) |
| 6 | The Morris worm propagated across the Arpanet by exploiting a debugging feature of sendmail that allowed remote execution. | "Used a debugging feature of sendmail (remote execution)" | 051 - Software Security, slide 7 | 051 - Software Security::s07::1 | 0.36 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7*

## PART A - QUESTION 7

### A7a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*List the four goals of access control and state what a reference monitor does in an access control system.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The four goals of access control are granting access, limiting access, preventing access and revoking access. | "Goals of access control: Granting access Limiting access Preventing access Revoking access" | 023 - Access Control and Authorization, slide 4 | 023 - Access Control and Authorization::s04::1 | 1.00 | supported (ste gate) |
| 2 | A reference monitor is the instrument that makes authorization decisions and realizes access control policies. | "Reference monitor makes authorization decisions." | 023 - Access Control and Authorization, slide 4 | 023 - Access Control and Authorization::s04::1 | 0.50 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA 

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 023 - Access Control and Authorization, slide 4*

### A7b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Describe the Chinese Wall model by stating the concern it is designed to address, explaining its simple security rule and its write-access rule, and explaining how a subject's permitted access changes over time.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The Chinese Wall policy is intended to resolve conflicts of interest. | "Brewer and Nash (1989) proposed a policy called the Chinese Wall Policy that addresses such conflicts of interest." | 024 - Formal Security Model, slide 21 | 024 - Formal Security Model::s21::1 | 0.71 | supported (ste gate) |
| 2 | It is classified as a confidentiality access control policy rather than an integrity policy. | "Strictly speaking, this is not an integrity policy, but an access control confidentiality policy." | 024 - Formal Security Model, slide 21 | 024 - Formal Security Model::s21::1 | 0.62 | supported (ste gate) |
| 3 | Under the simple security rule, access is granted only if the object lies within the Wall or in a completely different conflict of interest class. | "belongs to an entirely different conflict of interest class." | 024 - Formal Security Model, slide 25 | 024 - Formal Security Model::s25::1 | 0.20 LOW | partly supporte |
| 4 | The write rule allows a write only if the simple security rule permits it and no object readable by the subject lies in a different company dataset containing unsanitized information. | "Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information." | 024 - Formal Security Model, slide 26 | 024 - Formal Security Model::s26::1 | 0.75 | supported (ste gate) |
| 5 | Access rights are dynamic and depend on the subject's history of previous accesses. | "Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses" | 024 - Formal Security Model, slide 24 | 024 - Formal Security Model::s24::1 | 0.86 | supported (ste gate) |
| 6 | Once a subject accesses one company's information, it is blocked from companies in the same conflict class but remains free to access companies in other conflict classes. | "For example, if you access a file from Proton, you subsequently will be blocked from accessing any files from Perodua or Naza." | 024 - Formal Security Model, slide 24 | 024 - Formal Security Model::s24::1 | 0.15 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 24; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26*

## PART A - QUESTION 8

### A8a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain how a disclosure threat and a usurpation threat each affect the confidentiality, integrity and availability of a system's assets.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | A disclosure threat | "Disclosure - unauthorized access | 011 - | 011 - Introduction | 0.36 LOW | partly supporte |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | involves unauthorized access to information, which breaches confidentiality, and confidentiality services are the countermeasure against it. | to information" | Introduction to Computer Security, slide 10 | to Computer Security::s10::1 | | |
| 2 | A usurpation threat is unauthorized control of part of a system, and availability services are what counter this threat. | "Usurpation - unauthorized control of some part of a system" | 011 - Introduction to Computer Security, slide 10 | 011 - Introduction to Computer Security::s10::1 | 0.56 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 011 - Introduction to Computer Security, slide 10*

### A8b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State six facts about the Samy worm and the cross-site scripting (XSS) behaviour it exploited, covering how the malicious script was injected, how it spread between users, and the outcome of the incident.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The worm injected JavaScript into a user profile by manipulating document.body.innerHTML. | "Inject Javascript into a user profile using document.body.innerHTML" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.70 | supported (ste gate) |
| 2 | The worm retrieved the list of a user's heroes by issuing a GET request on a user profile. | "Get the list of user's heros by using a GET on a user profile" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.38 LOW | supported |
| 3 | The worm added Samy as a field by performing XML-HTTP on the addFriends page. | "Add Samy as a field by performing XML-HTTP on the addFriends page" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.78 | supported (ste gate) |
| 4 | Any user visiting an infected user's page had their own profile and friends list infected with the JavaScript and with Samy. | "Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.73 | supported (ste gate) |
| 5 | The incident eventually infected about 1,000,000 MySpace profiles. | "Eventually about 1,000,000 MySpace profiles were infected." | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.71 | supported (ste gate) |
| 6 | The underlying XSS weakness is that any web application returning user input without filtering is a potential XSS vulnerability, allowing arbitrary JavaScript to run in the user's browser. | "Any web application that returns user input without filtering is a potential XSS vulnerability!" | 052 - Web Security, slide 13 | 052 - Web Security::s13::1 | 0.56 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15*

## PART A - QUESTION 9

### A9a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain how NIDS sensors should be positioned in a network and give one typical location for such a sensor.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Sensors should be placed strategically so that the most valuable assets are defended. | "Place IDS sensors strategically to defend most valuable assets" | 062 - Intrusion Detection System, slide 7 | 062 - Intrusion Detection System::s07::1 | 0.88 | supported (ste gate) |
| 2 | A typical sensor location is just inside the firewall (or on the DMZ, server farm segment, or segment connecting mainframe/midrange hosts). | "Just inside the firewall" | 062 - Intrusion Detection System, slide 7 | 062 - Intrusion Detection System::s07::1 | 0.21 LOW | supported |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 062 - Intrusion Detection System, slide 7*

## A9b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Describe six preventive network security mechanisms and, for each, state the protection it provides to an organization's network.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | A firewall controls incoming and outgoing network traffic according to predetermined security policies. | "Control incoming and outgoing traffic on network with predetermined security policies." | 061 - Network Security, slide 3 | 061 - Network Security::s03::1 | 0.80 | supported (ste gate) |
| 2 | A proxy server acts as a firewall and web filter to improve data security and network performance. | "Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests." | 061 - Network Security, slide 3 | 061 - Network Security::s03::1 | 0.73 | supported (ste gate) |
| 3 | Network segmentation creates boundaries between segments whose assets share a common function, risk or role. | "Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization." | 061 - Network Security, slide 3 | 061 - Network Security::s03::1 | 0.75 | supported (ste gate) |
| 4 | A remote access VPN gives individual hosts or clients secure access to the organization network. | "Provides remote and secure access to an organization network to individual hosts or clients" | 061 - Network Security, slide 4 | 061 - Network Security::s04::1 | 0.89 | supported (ste gate) |
| 5 | Zero Trust Network Access limits each user to only the access and permission needed for their role. | "A user should only has access and permission that required to fulfill the role" | 061 - Network Security, slide 4 | 061 - Network Security::s04::1 | 0.50 | supported (ste gate) |
| 6 | IDS/IPS detect or prevent attacks such as brute force, denial-of-service and exploitation of network vulnerabilities. | "To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities." | 061 - Network Security, slide 4 | 061 - Network Security::s04::1 | 0.85 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4*

# PART A - QUESTION 10

© Hak Cipta Universiti Teknologi MARA 

## A10a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain two advantages that adopting an organisational code of ethics brings to a computing professional's conduct, and state what may happen to a member who fails to follow such a code.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | It makes acceptable standards of behaviour clearer to understand. | "Adds clarity to the understanding of acceptable standards of behavior." | 071 - Ethics and Computer Security, slide 8 | 071 - Ethics and Computer Security::s08::1 | 0.50 | supported (ste gate) |
| 2 | It communicates shared guidelines that everyone is expected to follow. | "Communicates common guidelines for everyone to follow." | 071 - Ethics and Computer Security, slide 8 | 071 - Ethics and Computer Security::s08::1 | 0.67 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 071 - Ethics and Computer Security, slide 8*

## A10b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Discuss the ethical responsibilities of computing professionals and organisations in protecting the privacy of users' personal information, with reference to professional codes of ethics and the constraints under which information specialists must operate.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Computing professionals are expected to follow a formal code of ethics and professional conduct, such as that of the ACM. | "Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct." | 071 - Ethics and Computer Security, slide 7 | 071 - Ethics and Computer Security::s07::1 | 0.60 | supported (ste gate) |
| 2 | Professional bodies such as AITP support members with education and information on relevant IT issues, helping them handle privacy concerns responsibly. | "provides quality IT-related education, information on relevant IT issues, and forums for networking with experienced peers and other IT professionals." | 071 - Ethics and Computer Security, slide 7 | 071 - Ethics and Computer Security::s07::1 | 0.31 LOW | partly supporte |
| 3 | The ACM maintains a code of ethics and professional conduct for computing professionals. | "Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct." | 071 - Ethics and Computer Security, slide 7 | 071 - Ethics and Computer Security::s07::1 | 0.86 | supported (ste gate) |
| 4 | Merely describing moral and ethical dimensions of ICT is insufficient; organisations must actively address privacy obligations. | "Simply describing may not be enough when discussing the moral and ethical dimensions of ICT" | 071 - Ethics and Computer Security, slide 3 | 071 - Ethics and Computer Security::s03::1 | 0.33 LOW | partly supporte |
| 5 | Users and especially information specialists have definite responsibilities to perform within ethical, moral and legal constraints, including protecting privacy. | "Users in general, and information specialists in particular, have definite responsibilities in terms of performing within ethical, moral, and legal constraints" | 071 - Ethics and Computer Security, slide 3 | 071 - Ethics and Computer Security::s03::1 | 0.75 | supported (ste gate) |
| 6 | Organisations must ensure that privacy protection is treated as part of the ethical and legal constraints under which ICT is used. | "performing within ethical, moral, and legal constraints" | 071 - Ethics and Computer Security, slide 3 | 071 - Ethics and Computer Security::s03::1 | 0.25 LOW | partly supporte |

© Hak Cipta Universiti Teknologi MARA 

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 071 - Ethics and Computer Security, slide 3; 071 - Ethics and Computer Security, slide 7*

# PART B - QUESTION 1

## B1a - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State the role of the TPM in a chain of trust, how the chain is built from hardware to software, and how the platform's trusted state is finally established.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The TPM is a tamper-resistant hardware module mounted in the platform that performs measurement, protected storage, integrity reporting and policy enforcement. | "Trusted Platform Module (TPM): a tamper-resistant hardware module mounted in a platform." | 073 - Trusted Computing, slide 6 | 073 - Trusted Computing::s06::1 | 0.47 LOW | partly supporte |
| 2 | In the chain of trust, each stage measures and validates the next stage. | "Each stage measures and validates the next one" | 073 - Trusted Computing, slide 8 | 073 - Trusted Computing::s08::1 | 0.67 | supported (ste gate) |
| 3 | The measurement results are recorded in Platform Configuration Registers (PCRs) located on the TPM. | "Measurements go into Platform Configuration Registers (PCRs) on the TPM" | 073 - Trusted Computing, slide 8 | 073 - Trusted Computing::s08::1 | 0.67 | supported (ste gate) |
| 4 | The chain begins at the hardware TPM and then proceeds through software components such as the RTM, TPM software stack, BIOS and kernel. | "The chain starts with the hardware TPM, then software:" | 073 - Trusted Computing, slide 8 | 073 - Trusted Computing::s08::1 | 0.39 LOW | partly supporte |
| 5 | At the end of the chain, the whole platform is verified to be in a trusted state. | "At the end, the entire platform is verified to be in a trusted state" | 073 - Trusted Computing, slide 8 | 073 - Trusted Computing::s08::1 | 0.67 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 073 - Trusted Computing, slide 6; 073 - Trusted Computing, slide 8*

## B1b - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Discuss the NGSCB/Nexus architecture by describing its two primary system components and the security functions each performs on the trusted platform.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Nexus is described as a special kernel forming the core of the trusted operating environment. | "Special kernel (core of the trusted operating)" | 073 - Trusted Computing, slide 13 | 073 - Trusted Computing::s13::1 | 0.62 | supported (ste gate) |
| 2 | Nexus isolates normal-mode processes from trusted-mode processes by separating them differently in memory. | "Isolate the process of normal mode and trusted mode differently in memory" | 073 - Trusted Computing, slide 13 | 073 - Trusted Computing::s13::1 | 0.67 | supported (ste gate) |
| 3 | Nexus authenticates and protects data that is entered, stored, | "Authenticate and protect data (entered, stored, communicated, and displayed) by data encryption" | 073 - Trusted Computing, slide 13 | 073 - Trusted Computing::s13::1 | 0.80 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA 

| | | | | | | |
|---|---|---|---|---|---|---|
| | communicated and displayed by means of encryption. | | | | | |
| 4 | The Nexus security kernel is authenticated at boot, authenticates trusted programs, and provides the application interface to the TPM without trusting the OS. | "Security kernel, authenticated on boot" | 073 - Trusted Computing, slide 14 | 073 - Trusted Computing::s14::1 | 0.33 LOW | partly supporte |
| 5 | The Nexus Computing Agent is a trusted software component that runs in trusted mode and communicates with Nexus. | "Runs in trusted mode that communicates with Nexus" | 073 - Trusted Computing, slide 15 | 073 - Trusted Computing::s15::1 | 0.62 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15*

# PART B - QUESTION 2

## B2a - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain five ways in which intrusion detection systems and related protection mechanisms are used to detect and defend against attacks on computer systems.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | An IDS detects malicious activity occurring in computer systems. | "Detects malicious activity in computer systems" | 062 - Intrusion Detection System, slide 2 | 062 - Intrusion Detection System::s02::1 | 0.71 | supported (ste gate) |
| 2 | An IDS can identify and stop an attack while it is still in progress. | "Identifies and stops attacks in progress" | 062 - Intrusion Detection System, slide 2 | 062 - Intrusion Detection System::s02::1 | 0.43 LOW | supported |
| 3 | An IDS supports forensic analysis after an attack has finished. | "Conducts forensic analysis once attack is over" | 062 - Intrusion Detection System, slide 2 | 062 - Intrusion Detection System::s02::1 | 0.38 LOW | supported |
| 4 | A passive detection system can only log and alert when an attack is identified. | "Can take passive action (logging and alerting) when an attack is identified" | 062 - Intrusion Detection System, slide 29 | 062 - Intrusion Detection System::s29::1 | 0.67 | supported (ste gate) |
| 5 | A passive detection system is unable to actively stop an attack that is in progress. | "Cannot take active actions to stop an attack in progress" | 062 - Intrusion Detection System, slide 29 | 062 - Intrusion Detection System::s29::1 | 0.50 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 062 - Intrusion Detection System, slide 2; 062 - Intrusion Detection System, slide 29*

## B2b - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain five threat classes and countermeasures described in the lecture, covering how threats are defined, how attacks relate to vulnerabilities, and how protection mechanisms and specific defences address these dangers.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | A threat is defined as an entity that | "Threat: object, person, or other entity representing a constant | 011 - Introduction to | 011 - Introduction to Computer Security::s28::1 | 0.86 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | represents a constant danger to an asset. | danger to an asset" | Computer Security, slide 28 | | | |
| 2 | An attack is described as a deliberate act that takes advantage of a vulnerability. | "Attack: a deliberate act that exploits vulnerability" | 011 - Introduction to Computer Security, slide 28 | 011 - Introduction to Computer Security::s28::1 | 0.67 | supported (ste gate) |
| 3 | Protection of assets involves prevention, detection and response techniques. | "Protection of assets encompasses prevention, detection and response techniques" | 011 - Introduction to Computer Security, slide 28 | 011 - Introduction to Computer Security::s28::1 | 0.86 | supported (ste gate) |
| 4 | Threats are potential violations of security, whereas attacks are actual violations. | "Threats: A threat is a "potential" violation of security" | 011 - Introduction to Computer Security, slide 9 | 011 - Introduction to Computer Security::s09::1 | 0.57 | supported (ste gate) |
| 5 | Sandboxing provides a safe, isolated environment for running or opening suspected insecure programs or files. | "Sandboxing A safe, protected and isolated environment in computer system to run or open suspected insecure programs or files." | 061 - Network Security, slide 26 | 061 - Network Security::s26::1 | 0.91 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 011 - Introduction to Computer Security, slide 28; 011 - Introduction to Computer Security, slide 9; 061 - Network Security, slide 26*

*End of marking scheme.*

© Hak Cipta Universiti Teknologi MARA 